

PROCÉDURE DE GESTION DES INCIDENTS DE SÉCURITÉ

Version 2 - approuvée par la direction le 15/01/2026

1. OBJET ET PÉRIMÈTRE

Cette procédure décrit la conduite à tenir face à un incident de sécurité touchant les systèmes d'information de Comptoir : application comptoir, postes de travail, messagerie, comptes des outils en ligne, ainsi que les données confiées par les clients.

2. DÉFINITIONS

Incident de sécurité : tout événement qui porte ou pourrait porter atteinte à la disponibilité, à l'intégrité ou à la confidentialité des informations (hameçonnage réussi, perte d'un ordinateur, accès non autorisé, logiciel malveillant, fuite de données).

Violation de données personnelles : incident entraînant, de manière accidentelle ou illicite, la destruction, la perte, l'altération, la divulgation non autorisée de données personnelles, ou l'accès non autorisé à de telles données.

3. RÔLES

Le **responsable sécurité** coordonne le traitement des incidents. Le **délégué à la protection des données** apprécie le risque pour les personnes et prépare les notifications. La direction décide des communications externes.

4. SIGNALEMENT INTERNE

Toute personne qui constate ou suspecte un incident de sécurité le signale **au responsable sécurité sous 1 heure**, par le canal #securite ou par téléphone, même en cas de doute. Il ne faut ni éteindre le poste concerné, ni tenter d'enquêter seul, ni supprimer de courriels suspects avant l'avis du responsable sécurité.

5. QUALIFICATION ET CONFINEMENT

Le responsable sécurité qualifie l'incident, en évalue la gravité et décide des mesures de confinement : révocation de jetons d'accès à l'API, réinitialisation de mots de passe, isolement d'un poste, blocage d'un compte.

6. NOTIFICATION À LA CNIL

En cas de **violation de données personnelles** présentant un risque pour les droits et libertés des personnes, Comptoir la **notifie à la CNIL dans un délai de 72 heures** après en avoir pris connaissance, conformément à l'article 33 du RGPD. Si toutes les informations ne sont pas disponibles, une notification initiale est faite dans ce délai puis complétée.

Lorsque le risque est élevé, les personnes concernées sont également informées dans les meilleurs délais. Les clients dont les données sont hébergées par Comptoir sont prévenus par le directeur commercial.

7. RÉOLUTION ET RETOUR D'EXPÉRIENCE

Après rétablissement, le responsable sécurité rédige un compte rendu : chronologie, cause, données concernées, mesures prises. Un retour d'expérience est organisé dans les deux semaines avec les équipes concernées ; les actions correctives sont suivies jusqu'à leur clôture.

8. REGISTRE DES VIOLATIONS

Toutes les violations de données personnelles, y compris celles qui ne sont pas notifiées à la CNIL, sont consignées dans le registre des violations tenu par le délégué à la protection des données.

9. SENSIBILISATION

Chaque nouvel arrivant prend connaissance de la présente procédure lors de son intégration. Un exercice de simulation est organisé une fois par an.